

ورقة امتحانية — الجابتر السادس

أمن تطبيقات الويب

الخلاصة المكتفة: الثغرات · الأدوات · الممارسات · المعادلات · المصائد · المفردات

Web Application Security · المصدر: 23 صفحة ← الورقة: 4 صفحات

قاعدة الاستعمال: اقرا هذي الورقة أولاً وبورقة وقلم. لا تفتح layer-tri إلا لما شي يلخبطك. ★ المستند الثالث فقط فيه الثغرات — الباقي كلام إداري.

1 الثغرات الست (الأهم — احفظ الجدول حرفياً)

الثغرة	كيف تشتغل	الحماية
SQL Injection (SQLi)	إدخال المستخدم يدخل مباشرة بالاستعلام. تنويعات: blind NoSQL injection · SQLi	Parameterized queries / prepared statements + input validation
Cross-Site Scripting (XSS)	JavaScript خبيث ينقذ بمتصفح الضحية. تنويع: DOM-based (بالSPAs)	Output encoding + CSP + sanitization
CSRF	يخدع المتصفح يرسل طلب مصادق عليه بدون علم الضحية	SameSite cookie + anti-CSRF tokens
API / Microservices	BOLA (تحويل الكائن مكسور) + excessive data exposure	Object-level authorization + schema validation + rate limiting
Supply Chain	مكتبات طرف ثالث بلا تدقيق · dependency confusion · malicious package injection	Dependency vetting + SCA + pinning
Cloud-Native / Serverless	container misconfigurations · insecure orchestration (K8s API) · event injection	Hardening + policy enforcement + monitoring

الجذر الجامع (اكتبه بأي جواب سيناريو): إدخال غير موثوق يوصل ل sink حسّاس — والتحقق + الترميز (encoding) + التحويل يقطعون السلسلة.

2 المبادئ الاستراتيجية الأربعة

المبدأ	المعنى بجملة
Defense-in-Depth	طبقات متراكبة — كل طبقة تفترض إن اللي قبلها انكسرت
Zero Trust	«Always Verify, Never Trust» — الداخل مو موثوق تلقائياً
Security by Design	الأمن من التصميم (shift-left)، مو يُضاف لاحقاً
Risk-Based Prioritization	الموارد محدودة ← نرتّب حسب الخطر (FAIR · CVSS)

3 الأدوات والممارسات (تعداد — يُحفظ)

الأدوات (Tools): - WAF — فلترة بطيئة التطبيق (ضابط تعويضي، ما يصلح الثغرة) - Vulnerability Scanners — كشف آلي - RASP — حماية داخل التطبيق، تشوف البيانات بعد فك التشفير - Penetration-Testing Platforms — يمسخ اللي يفوت على السكانر - SIEM + Threat Intelligence — ربط الأحداث + مؤشرات - Emerging Tools — ML/AI + ترقيع آلي

الممارسات (Practices): - Secure Coding · Authorization & Authentication · Secure Configuration & Lifecycle · DevSecOps · IR & Continuous Monitoring · Hardening

4 المعادلات (6)

المعنى	المعادلة
تقليل الثغرات بدورات DevSecOps — فقال إذا $\alpha > \beta/V_t$	$V_{t+1} = V_t(1 - \alpha) + \beta$
خطر الثغرة = احتمال × شدة × أثر	$R_i = L_i \cdot S_i \cdot I_i$
الموثوقية عبر الزمن (λ = معدل الفشل + النشاط العدائي)	$R(t) = e^{-\lambda t}$
موثوقية المتوازي (redundancy) ← الموثوقية تطلع	$R_{sys} = 1 - \prod_{i=1}^n (1 - R_i)$
موثوقية السلسلة ← الموثوقية تنزل	$R = \prod_i R_i$
التوافر (Availability)	$A = \frac{MTBF}{MTBF + MTTR}$

5 المصائد (10)

الجواب	المصيصة	#
Parameterized queries	الوقاية من SQLi؟	1
Output encoding + CSP	الوقاية من XSS؟	2
ضابط تعويضي — ما يصلح الثغرة ✗	WAF يكفي؟	3
XSS ينفذ كود · CSRF يستغل الجلسة بدون كود ✗	XSS = CSRF؟	4
Strategy أطر مستدامة · Tactics رد فعل ✗	Tactics = Strategy؟	5
الأمن من التصميم ✗	Security by Design = فايروول بالآخر؟	6
RTO = زمن التوقف · RPO = بيانات مفقودة ✗	RPO = RTO؟	7
تطلع (parallel) · بالسلسلة تنزل	نضيف redundancy ← الموثوقية؟	8
shared responsibility ✗	Cloud = مسؤولية المزود؟	9
BOLA = تخويل · Excessive = كشف بيانات ✗	excessive data exposure = BOLA؟	10

6 المفردات الإنكليزية (الأستاذة تشدد عليها)

vulnerability · exploit · exploitability · remediation · patching · hardening · least privilege · object-level authorization (BOLA) · excessive data exposure · dependency confusion · container misconfiguration · orchestration · event injection · redundancy · failover · business continuity · disaster recovery · availability · resilience · compensating control

(شكذ بيانات نخسى) Recovery Point Objective = **RPO** · **RTO** = Recovery Time Objective (شكذ نتوقف)

أسئلة استرجاع (غظها واختبر نفسك)

1. الثغرات الست + حماية كل واحدة؟

SQLi ← parameterized queries · XSS ← output encoding + CSP · CSRF ← SameSite + tokens · API ← object-level authz · Supply Chain ← SCA + pinning · Cloud ← hardening.

2. المبادئ الأربعة؟

Defense-in-Depth · Zero Trust · Security by Design · Risk-Based Prioritization.

3. الأدوات الخمس + الناشئة؟

WAF · Scanners · RASP · Pen-test · SIEM — والناشئة ML/AI + ترقيع آلي.

4. الممارسات الخمس؟

Secure Coding · Auth/Authz · Hardening · Monitoring & IR · DevSecOps.

5. شنو BOLA؟

Broken Object-Level Authorization — المستخدم يوصل لكائن ما إله حق فيه (ما كو تحقق من الملكية).

6. شنو dependency confusion؟

حزمة خبيثة بنفس اسم حزمة داخلية ← مدير الحزم يسحبها.

7. الفرق Series/Parallel بالموثوقية؟

Series ← تنزل ($\prod R_i$) · Parallel/Redundancy ← تطلع ($1 - \prod(1 - R_i)$).

8. RTO و RPO؟

$RTO = \text{زمن التوقف المسموح} \cdot RPO = \text{البيانات المسموح خسارتها.}$

9. WAF مقابل RASP؟

WAF بطبقة التطبيق (يُعمى بالتشفير) · RASP داخل التطبيق (يشوف البيانات بعد فك التشفير).

10. الدرس الجامع؟

الأمن نُظْمِي = حوكمة + تقنية + تحليل كمّي — من التصميم (shift-left) إلى الصمود (continuity).

المرجع الكامل (61 صفحة): [W06_Chapter6_TriLayer.pdf](#). هذي الورقة = ما تحتاجه للامتحان. المرجع = لما شي يلخبطك.